

DIAGNOSTICO DE EXPOSICIÓN

Análisis inicial de exposición externa.



Heimdall Threat Advisory

Consultoría en ciberseguridad para empresas

Organización auditada: hotel.mx
Análisis de superficie de ataque.

DIAGNOSTICO DE EXPOSICIÓN EXTERNA Y EVALUACIÓN DE SUPERFICIE DE ATAQUE.

Fecha del informe: Junio-15-2026.

Periodo de auditoria: [Jun-01-2026]-[Jun-14-2026].

Entidad auditada: hotel.mx

Auditor: José Ricardo Flores Martínez.

Responsable	Puesto	Fecha de entrega
	Director general	Junio 15 2026
	Gerente IT	Junio 15 2026
	Responsable de desarrollo	Junio 16 2026

Índice de contenido.

1. Pag 2 - Resumen ejecutivo (motivación, alcance, objetivos y riesgo actual).
2. Pag 3 – Hallazgos principales.
3. Pag 4 – Tabla de información y servicios expuestos.
4. Pag 5- Propuesta de seguimiento.
5. Pag 5- Conclusiones.
6. Pag 6- Limitaciones y responsabilidades.
7. Pag 7- Anexo de imágenes informativas.

1: Resumen ejecutivo.

El presente informe de análisis de exposición se realizó mediante un proceso de recolección de información de fuentes abiertas (OSINT) para determinar el nivel de exposición externa de su organización (visibilidad de servicios, tecnologías y activos desde internet).

1.1 Contexto: La plataforma corresponde al catálogo de habitaciones y salones de eventos, cuenta con servicio de reservaciones subcontratado y facturación por lo que maneja información personal de alto nivel de confidencialidad. La dirección principal resuelve a la IP del servidor origen directamente, aparentemente sin pasar por algún servicio de enmascaramiento o protección de tipo proxy reverso que oculte la información y limite el acceso a los puertos de comunicación.

El proceso reveló una infraestructura aparentemente desactualizada, con varios servicios y sistemas sin un soporte oficial activo, así como varios puertos de comunicación visibles que exponen información crítica sobre las tecnologías que componen el activo.

1.2 Riesgo del activo: Se asigna un valor de riesgo potencial de **nivel 4** (76: alto) correspondiente al promedio de las valoraciones individuales realizadas y considerando el tipo de información que maneja, el nivel de impacto al negocio en caso de materializarse algún incidente y el tipo de activo. Sin embargo, la confirmación del **nivel de riesgo** no considera controles de seguridad o configuraciones que no sean visibles desde internet ya que, quedan fuera del alcance de este análisis. La confirmación de estos requeriría de un proceso de auditoria técnica completo y un análisis de riesgos los cuales requieren aprobación por parte del cliente.

Nivel 1(0 - 20): Riesgo insignificante / informativo.

Nivel 2 (21 - 40): Riesgo bajo / asumible.

Nivel 3 (41 - 60): Riesgo moderado / requiere atención.

Nivel 4 (61 - 80): Riesgo alto / requiere mitigación urgente.

Nivel 5 (81 - 100): Riesgo crítico / inaceptable.

1.3 Alcance: El análisis se enfoca y limita a información pública accesible desde internet sin utilizar ningún tipo de *exploit* o interacción directa con el activo analizado, el proceso de enumeración se realiza únicamente con el fin de determinar qué es lo que vería un atacante externo, determinar que tecnologías se utilizan, sus versiones y posibles configuraciones.

2: Hallazgos.

A continuación, se enumeran los principales hallazgos encontrados durante el proceso de análisis. Los servicios y tecnologías listadas representan condiciones observables desde internet, no necesariamente presentan una vulnerabilidad explotable, sin embargo, muchas de ellas cuentan con antecedentes de riesgos de seguridad documentados públicamente por lo que se recomienda ponerlas a consideración.

- Tecnologías fuera del ciclo de vida EOL y/o sin soporte oficial activo (IIS 7.5 y PHP 5.4.36).
- Servicio de terminal de administración visible desde internet.
- Base de datos identificable desde el exterior con una versión antigua y sin soporte activo.
- Servicio de correo electrónico visible desde internet (potencialmente identificable en procesos de reconocimiento).
- Servicio de carga y descarga de archivos libre (Filezilla 0.9.41 Beta) la cual no cuenta con soporte activo. Este servicio se ha asociado a la vulnerabilidad “Heartbleed” de Open SSL 1.0.1 y anteriores, derivado del uso de bibliotecas heredadas según reporte de INCIBE.
- Servicios de administración y comunicación interna visibles desde Internet.
- El dominio comercial apunta directamente a la dirección IP del servidor ubicado en Santiago de Querétaro, México.

La confirmación de las condiciones de riesgo relacionadas a los hallazgos listados anteriormente requeriría la implementación de pruebas directas que confirmen la presencia y efectividad de controles de seguridad o configuraciones compensatorias.

3: Tabla de principales servicios expuestos.

A continuación, se muestra la información más relevante sobre las tecnologías observadas durante el proceso de análisis.

Dominio analizado	hoteldiana.mx	
Dirección IP y PTR	000.000.000.37 / host37.hotel.mx	Estado / riesgo preliminar
ASN	AS0001	Permite contextualizar la red e infraestructura durante procesos de reconocimiento.
ISP	UNINET	
Servidor Web	Windows server: IIS 7.5 (EOL desde enero 2020)	N 5: 85 - Sin soporte activo.
Web Framework	Microsoft ASP.NET	N 3: 55 – Framework asociado a tecnologías legacy.
Tecnología web	PHP 5.4.36 (EOL)	N 4: 80 - Tecnología heredada, fuera del ciclo de vida
Servicio de transferencia de archivos FTP/SFTP	FileZilla server 0.9.41 Beta (EOL)	N 4: 75 – Versión obsoleta, riesgos documentados públicamente
Servicio BDD	MySQL 5.6.26 (EOL)	N 4: 80 – Exposición directa. Requiere validación
Exposición	Visibilidad directa desde internet	N 4: 80 – Sin protección perimetral aparente.
Observaciones de auditor	Las tecnologías incluidas en la presente tabla cuentan con antecedentes de vulnerabilidades importantes documentadas públicamente, la explotabilidad de estas condiciones de riesgo puede modificarse por los controles internos implementados.	Nivel de riesgo general: 76 Alto (promedio)

El nivel de riesgo asignado a cada servicio corresponde al riesgo inherente asociado a las condiciones observadas desde el exterior (sin tomar en cuenta controles de seguridad que no sean visibles desde internet), un proceso de auditoria técnica profunda y análisis de controles de seguridad implementados puede modificar el nivel asignado. Por su parte, el nivel de riesgo general corresponde al promedio aritmético de los niveles individuales

4: Seguimiento.

Para poder confirmar si las condiciones identificadas, así como aquellas que no fueron identificadas debido al alcance de este análisis ya que requerirán un proceso de interacción directa con los servicios pudieran representar un riesgo para la organización se requiere de un proceso de auditoría, análisis y prueba de explotabilidad que permita profundizar sobre las configuraciones, controles de acceso, versiones y mecanismos de protección.

Para disminuir el nivel de exposición actual se recomienda:

- Validar la necesidad de mantener los servicios expuestos.
- Revisar configuraciones de acceso.
- Confirmar el estado de actualización de los sistemas.
- Realizar pruebas autorizadas para determinar explotabilidad.
- Elaborar un análisis de riesgos que permita priorizar remediaciones según impacto al negocio y los recursos disponibles.

Una revisión técnica autorizada permitiría confirmar la aplicabilidad de los antecedentes de riesgo identificados y determinar si las condiciones observadas son explotables, si existen controles compensatorios que mitiguen efectivamente el riesgo y cuál es el nivel de riesgo residual/real para el activo.

5: Conclusiones.

El proceso de análisis realizado sobre la organización permitió identificar múltiples tecnologías fuera de su ciclo de vida por lo cual no cuentan con un soporte oficial activo y son accesibles desde internet. Aunque la información observada no permite confirmar la existencia de vulnerabilidades explotables sin acceso interno para una validación adicional, sí incrementa la incertidumbre sobre el nivel real de exposición del activo, así mismo, dificulta determinar si los controles actualmente implementados son suficientes para protegerlo frente a amenazas conocidas.

La información observada sugiere que el activo pudiera formar parte de una red corporativa según el nombre del dominio al que pertenece (HDGDLMAIL01.hotel.mx). La validación adicional podría

determinar si el nivel de exposición pudiera tener implicaciones sobre otros activos de la red ya que la observación de nomenclaturas internas asociadas a la infraestructura tecnológica, si bien no representan una vulnerabilidad por sí misma, puede facilitar actividades de reconocimiento y perfilado.

La exposición de servicios críticos y el uso de componentes sin soporte activo pueden incrementar la superficie de ataque y la probabilidad de que una condición de seguridad sea aprovechada derivando en incidentes operativos, interrupciones de servicio o costos de recuperación. La validación técnica de estos hallazgos permitiría reducir la incertidumbre actual, confirmar el nivel real de exposición y priorizar acciones de remediación de acuerdo con el impacto potencial para la organización.

6: Limitaciones y descargo de responsabilidad.

El presente análisis se basa en la información recopilada durante el periodo comprendido entre el 01 y el 14 de junio de 2026, bajo un enfoque de auditoría de caja negra y sin acceso interno a la infraestructura.

Los resultados y conclusiones están limitados a los activos identificados durante el proceso de recopilación de información, por lo que podrían existir otros sistemas o vulnerabilidades no detectadas dentro del alcance definido.

La implementación de las recomendaciones propuestas reduce la probabilidad e impacto de los riesgos identificados, pero no elimina completamente la posibilidad de incidentes de seguridad.

Los niveles de riesgo fueron determinados sin considerar controles internos, configuraciones, mecanismos de segmentación, restricciones de acceso u otras medidas de protección que no fueran observables desde Internet.

Evidencia 3: Confirmación de puertos abiertos y versiones de servicios expuestos.

```
(kali@kali)-[~]
└─$ nmap -iL -p- -O -T1 -o 21.22.53.88,110,135,443,465,587,3396 .37
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-31 23:12 -0400
Nmap scan report for host33.hotelidiana.mx ( .37)
Host is up (0.492s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          FileZilla ftpd 0.9.41 beta
22/tcp    open  ssh          Microsoft Terminal Service
33/tcp    open  domain      Microsoft DNS 6.1.7681 (1001575) (Windows Server 2008 R2 SP1)
80/tcp    open  http        Microsoft IIS httpd 7.5
135/tcp   open  msrpc       MailEnable POP3 Server
135/tcp   open  msrpc       Microsoft Windows RPC
443/tcp   open  ssl/https   Microsoft IIS https 7.5
443/tcp   open  smtp        MailEnable smtpd 58.49--
587/tcp   open  smtp        MailEnable smtpd 58.49--
3396/tcp  open  mysql       MySQL 5.5.28-log

Warning: OSscan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: WIMP adapter[slip](general purpose)
Running (NVT 60551960): ATST unneeded (91%), Oracle VirtualBox (91%), Slirp (91%), QEMU (88%)
OS CPE: cpe:/o:oracle:virtualbox:cpe:/a:danny.gaspardovskis:slirp:cpe:/a:qemu:qemu
Aggressive OS guesses: ATST ROM210 vmlite gateway (91%), Oracle VirtualBox Slirp NAT bridge (91%), QEMU user mode network gateway (88%)
No exact OS matches for host (test conditions non-ideal).
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows, cpe:/a:microsoft:windows_server_2008r2:sp1

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 126.68 seconds

(kali@kali)-[~]
└─$ nmap -iL -p- -O -T1 -o 20.21.22.53,88,110,135,443,465,587,3396 .37
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-31 23:16 -0400
Nmap scan report for host33.hotel .mx ( .37)
Host is up (0.492s latency).

PORT      STATE SERVICE      VERSION
20/tcp    filtered  ftp-data     FileZilla ftpd 0.9.41 beta
21/tcp    open  ftp          FileZilla ftpd 0.9.41 beta
33/tcp    open  domain      Microsoft DNS 6.1.7681
80/tcp    open  http        Microsoft IIS httpd 7.5
135/tcp   open  msrpc       MailEnable POP3 Server
135/tcp   open  msrpc       Microsoft Windows RPC
443/tcp   open  ssl/https   Microsoft IIS https 7.5
443/tcp   open  smtp        MailEnable smtpd 58.49--
587/tcp   open  smtp        MailEnable smtpd 58.49--
3396/tcp  open  mysql       MySQL 5.5.28-log

Warning: OSscan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: WIMP adapter[slip](general purpose)
Running (NVT 60551960): ATST unneeded (91%), Oracle VirtualBox (91%), Slirp (91%), QEMU (88%)
OS CPE: cpe:/o:oracle:virtualbox:cpe:/a:danny.gaspardovskis:slirp:cpe:/a:qemu:qemu
Aggressive OS guesses: ATST ROM210 vmlite gateway (91%), Oracle VirtualBox Slirp NAT bridge (91%), QEMU user mode network gateway (88%)
No exact OS matches for host (test conditions non-ideal).
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows, cpe:/a:microsoft:windows_server_2008r2:sp1

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 126.68 seconds
```

Evidencia 4: Fuga de información por banners/encabezados HTTP (curl).

```
(kali@kali)-[~]
└─$ curl -I -L -A "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Geko) Chrome 120.0.0.0 Safari/537.36" https://hotel .mx
HTTP/1.1 200 OK
Content-Length: 0
Content-Type: text/html
Server: Microsoft-IIS/7.5
X-Powered-By: PHP/5.4.36
X-Powered-By: ASP.NET
Date: Mon, 01 Jun 2026 23:12:05 GMT
```